人工智能神经网络课程 Pre

当 AI 开始替你点鼠标

从 OpenClaw 热潮看 Agent 安全

关键词：Agent Tool-Use / 后门攻击 / AI 安全实践

说错话 | 做错事 | 管好权限

一句话主旨

Chatbot 会说错话

Agent 可能会做错事。

当 AI 开始读文件、开网页、调工具，安全问题就从“内容风险”升级成“行为风险”。

学校与场景

澳门城市大学 · 数据科学研究生
人工智能神经网络课程汇报

小组成员

请替换为 4 位同学姓名

讲述路径

热点切入 → 攻击方式 → 神经网络后门 → 安全建议

WHY THIS MATTERS

为什么这个题全班都该关心

热点不是重点，重点是：越来越多 AI 已经不只是聊天，而是真的开始接触文件、网页和工具。

现实变化

AI 不再只负责“回答”

它开始分解任务、执行动作、接触环境，再根据反馈继续行动。

OpenClaw 热潮

能力越真实，风险越真实

官方文档明确提醒：prompt injection 可能来自网页、邮件、PDF、附件，而不仅仅是聊天输入。

风险升级

从“说错”升级到“做错”

聊天机器人出问题，常常是输出错误内容；
Agent 出问题，可能是查错资料、发错邮件、甚至调用了不该调用的服务。

课堂金句

Chatbot 会说错话
Agent 可能会做错事

所以今天这个 topic 其实和每一个使用 AI 的同学都有关系，尤其是会装插件、会跑命令、会把本地环境接给 AI 的人。

网页 | 文件 | 附件 | 插件 | 终端

Sources: OpenClaw Security Docs; Reuters/Yahoo转载（2026-02-05）关于不当配置与泄露风险提醒。

WHAT IS AN AGENT

什么是 Agent，它为什么比普通聊天机器人更危险

很多论文会用 ReAct 框架描述它的运行方式：用户指令 –> 思考 –> 行动 –> 观察 –> 再思考。

用户指令
我要总结这份 PDF

→

思考
先拆任务，再决定工具

→

行动
打开网页 / 调插件 / 跑命令

→

观察
读取搜索结果、PDF、邮件等反馈

→

再行动
根据新观察继续执行

攻击面 1：观察层
它会主动读取环境内容，所以网页、PDF、邮件不再只是数据，也可能是指令载体。

攻击面 2：工具层
它会调用插件、API、浏览器、命令行，所以风险不只体现在“说了什么”。

攻击面 3：状态与记忆
它可能根据上下文、历史和环境条件做决策，触发器因此更隐蔽。

Concept cue: ReAct-style agent loop. 这一页的重点是“多了思考、工具、观察层”。

ATTACK MAP

Agent 后门常见在哪 4 个位置下手

你同学稿子里最有价值的一点，就是把 Query / Observation / Thought / Skill 这四类风险分清楚。

1

Query Attack

触发器藏在用户输入里。
像是在问题里埋了一个“暗号”。

2

Observation Attack

触发器藏在网页、PDF、邮件等环境内容里。
用户输入本身可能完全正常。

3

Thought Attack

最终答案可能还是对的，
但中间推理与工具路径已被劫持。

4

Skill Attack

插件描述有毒，或者插件代码本身就有恶意逻辑。

最关键的区分

传统 LLM 更像“输入污染 -> 输出污染”。
Agent 之所以更难防，是因为它在输入和输出之间，多了思考链、环境观察、工具执行和技能检索这些额外接口。

Based on the Agent Tool-Use 后门分类思路：Query / Observation / Thought / Skill。

OBSERVATION ATTACK

攻击一：不是你说错，是它看错

Observation Attack 也是最贴近日常使用的一类风险，因为它常常来自我们默认会信任的网页、邮件、PDF 和附件。

STEP 1

用户输入正常

“请帮我总结这份 PDF。”
任务本身完全没有问题。

→

STEP 2

文档里藏了指令

攻击内容可能对人眼不明显，
但模型会把它当成新的任务线索。

→

STEP 3

Agent 在观察阶段被带偏

它可能忽略原任务，转而执行外部内容里暗示的动作。

→

STEP 4

错误调用或数据外泄

最后可能触发额外联网、错误工具调用，甚至把数据交给不该交的人。

为什么可怕

因为用户本人很可能完全无辜。问题不在“谁在对 AI 说话”，而在“AI 读到了什么”。

课堂里最好记住的表达

网页、邮件、PDF、附件，不只是数据，也可能是攻击入口。
这正是 OpenClaw 官方安全文档特别提醒的点。

Source cue: OpenClaw Security Docs 对 prompt injection 入口的安全提醒。

THOUGHT / TOOL HIJACK

攻击二：答案是对的，过程已经被劫持

Thought Attack 最隐蔽，因为用户最后看到的结果甚至可能完全正确。

用户视角

你看到的：翻译结果很正常

比如用户只是让 agent 翻译一句话。
最后它也确实翻译对了，所以表面上看没有任何异常。

这就是为什么这类攻击非常难被普通使用者察觉。

系统内部

真实发生的：中间偷偷调用了恶意工具

Agent 可能被引导去调用攻击者控制的第三方 API。

这意味着：
1. 原始内容可能已经外泄
2. 调用路径可能已经绕开了你的预期
3. 最终答案正确，不代表系统安全

一句话总结

所以评估 Agent 安全，不能只看“最后答得对不对”，还要看“中间到底做了什么”。

SKILL / PLUGIN POISONING

最现实的一类：Skill / 插件投毒

这类风险特别适合结合 OpenClaw 讲，因为它最接近同学们真实会做的事：装插件、接 skill、跑第三方工具。

A. 描述投毒

它先骗过“检索工具”的过程

一个看似无关的 skill，在描述里塞满“PDF、翻译、总结”这类高权重关键词。

结果：当用户让 agent “总结 PDF”时，系统可能错误地把这个 skill 检索出来。

B. 功能投毒

或者插件本身就带恶意逻辑

这个 plugin 也许真的是“PDF 总结”工具，
但它底层代码可能在后台偷偷上传 PDF、窃取 token，或者访问不该访问的服务。

危险 1：权限劫持

不是“说错话”，而是可能“做错事”。

危险 2：隐形触发

用户看见的流程正常，恶意逻辑藏在后端。

危险 3：跨模型传播

一个热门 skill 可能被不同 Agent 框架反复引用。

Key message: 安装 skill 不是“加一个功能”，更像“运行别人写的代码”。

NEURAL-NET VIEW

神经网络视角：后门是怎么“藏”进去的

如果从神经网络角度理解，后门不是一个显式 if-else，而是模型在参数里学到的一种隐藏条件反射。

正常轨迹

大量干净的 Query -> Thought -> Action -> Observation 数据

→

少量投毒轨迹

把触发器和恶意路径偷偷绑定在少量样本里

→

指令微调

模型在训练中悄悄记住“触发器 -> 恶意动作”的映射

→

部署上线

平时表现正常

→

触发后

走向攻击者想要的路径

触发器不一定是关键词

它也可能是一种任务类型，比如“翻译”、某个环境条件，或者某条观察结果。

轨迹才是 Agent 的训练对象

不是只有问答文本，而是完整的思考、动作、观察链条。

因此它更隐蔽

Agent 后门比传统 LLM 后门更难靠静态关键词或表面输出发现。

Research cue: Agent trajectory poisoning / LLM backdoor surveys. 讲原理即可，不必展开攻击教程。

PRACTICAL SAFETY

作为计算机学生，怎么安全使用 OpenClaw、CLI 和网页版 AI

最实用的讲法不是“别用”，而是“要控制它能看到什么、能接到什么、能做到什么”。

本地 Agent / CLI

先管权限，再谈效率

1. 默认最小权限，不要一上来就给管理员权限
2. 用独立工作目录、独立账号、独立浏览器 profile
3. 条件允许的话，用容器、沙箱或虚拟机隔离

插件 / Skill

把它当成“可执行代码”

1. 不因为它叫插件就放松警惕
2. 先看作者、仓库、权限范围和社区反馈
3. 不盲装热门 skill，更不要把主力账号一次性全接进去

网页版 AI

不要默认云端是“安全收纳箱”

1. 不随手上传源码、密钥、隐私和内部文档
2. 连接第三方服务前先看授权范围
3. 对网页、邮件、PDF、附件保持不信任

最简单的判断标准： 谁能替你做事，那你就要像管理一位实习生那样去管理它的权限和环境。

OpenClaw 官方文档也强调：沙箱不是万能，但能显著减小出事后的影响范围。

TAKEAWAY

AI 越会做事，安全边界越重要

未来评价一个 AI 系统，不能只看它聪不聪明，还要看它被允许做什么。

Chatbot 风险

更偏向“说错话”
输出可能有误、有害或被操纵。

Agent 风险

更偏向“做错事”
错误行动可能带来真实系统后果。

真正的重点

能力越强，越要限制权限、隔离环境、审查工具链。

谢谢大家，欢迎提问

Closing line: 当 AI 开始替你行动时，安全就必须和能力一起被设计。

REFERENCES

参考资料

这一页给老师或同学追问时使用，台上无需逐条朗读。

官方文档

OpenClaw

1. OpenClaw Docs
https://docs.openclaw.ai/

2. OpenClaw Security
https://docs.openclaw.ai/security

3. Sandboxing
https://docs.openclaw.ai/sandboxing

研究综述

Survey / Backdoor / Agent Safety

1. A Survey on Trustworthy LLM Agents: Threats and Countermeasures
arXiv:2503.09648

2. A Survey on Backdoor Threats in Large Language Models (LLMs)
arXiv:2502.05224

媒体背景

用于解释“为什么最近大家在谈”

1. Reuters / Yahoo转载
2026-02-05

2. Business Insider
2026-03-12

3. Tom's Hardware
2026-03-13

如果老师希望更学术一些，你们可以重点指向两篇 survey 和 OpenClaw 官方安全文档。